

Group name: Group 2 - NA

Authors: Philip Ufuah, Emmanuel Aderogba, Justice Alucho, Omotayo Ogunnika, Davidmarie Okon

Please find [attached](#) the link to the supplementary documents, which includes:

1. Cover Page
2. Executive Summary
3. Nmap Scan Results
4. Risk Register
5. Risk Matrix
6. Internal Audit Check List

<https://docs.google.com/spreadsheets/d/14Re4L4cWD3PE4oLp2XbZmzQnoHpiXa6JRj7DjyFKw0E/edit?usp=sharing>

Penetration Testing Policy and Vulnerability Management Policy

1. Penetration Testing Policy

1.0 Purpose

The purpose of this Penetration Testing Policy is to define the requirements, authorization, scope, and execution of penetration testing activities within the organization. The policy ensures testing is performed in a controlled, safe, and compliant manner to validate security controls, identify weaknesses, and support continuous improvement.

2.0 Scope

This policy applies to all organizational assets, including but not limited to:

- Internal and external networks
- Servers, endpoints, and cloud infrastructure
- Web applications, APIs, and mobile applications
- Third-party hosted systems (where contractual permission exists)
- Employees, contractors, and third-party testers involved in testing activities

3.0 Policy Statement

The organization shall conduct penetration testing on a recurring basis and after significant changes to critical systems. All penetration testing must be approved, authorized, documented, and executed in accordance with legal and regulatory requirements.

4.0 Roles and Responsibilities

- **CISO / Security Manager:** Approves testing, defines scope, and ensures compliance.
- **IT Operations:** Provides system access, coordinates change windows, and monitors system stability.
- **Penetration Testers (Internal or External):** Conduct tests following industry standards (OWASP, NIST, OSSTMM).
- **System Owners:** Ensure remediation plans are completed according to risk severity.

5.0 Rules of Engagement

Penetration testing must follow these guidelines:

- Testing activities **must be authorized in writing**.
- A clear scope, timeframe, and methodology must be defined.
- Testers may not exceed agreed-upon boundaries (“no-touch zones”).
- Exploitation must avoid data corruption, operational disruption, or service outages.
- Vulnerabilities discovered must be reported immediately through secure channels.
- Sensitive data collected must be securely stored and destroyed after reporting.

6.0 Frequency of Testing

Penetration tests shall be conducted:

- Annually for all critical systems
- After major system upgrades or architectural changes
- After significant security incident

7.0 Reporting Requirements

A final penetration test report must include:

- Executive summary
- Scope and methodology
- Identified vulnerabilities with severity ratings
- Proof-of-concept (when safe)
- Recommended remediation steps
- Metrics for tracking closure of findings

8.0 Compliance

Violations of this policy may result in disciplinary action and could impact compliance with regulations such as PCI-DSS, ISO 27001, NIST 800-53, HIPAA, and GDPR.

2. Vulnerability Management Policy

1.0 Purpose

The purpose of the Vulnerability Management Policy is to ensure timely identification, assessment, prioritization, and remediation of security vulnerabilities across all organizational assets, thereby reducing exposure to threats and maintaining acceptable risk levels.

2.0 Scope

This policy applies to:

- All IT systems, applications, databases, network devices, and cloud resources
- All business units, employees, contractors, and third-party service providers
- All vulnerability sources including automation, manual testing, and threat intelligence feeds

3.0 Policy Statement

The organization shall maintain a continuous vulnerability management program that includes scanning, risk assessment, prioritization, remediation, verification, and reporting of vulnerabilities.

4.0 Roles and Responsibilities

- **Security Team:** Performs vulnerability scanning, risk scoring, and reporting.
- **IT Operations / System Owners:** Apply patches and implement remediation actions.
- **CISO / Security Manager:** Oversees the vulnerability management lifecycle and ensures compliance.
- **Third-Party Vendors:** Must remediate vulnerabilities in systems they manage according to organizational requirements.

5.0 Vulnerability Identification

- Automated scans must be performed on all networks and systems at least **monthly**.
- Critical infrastructure must be scanned weekly or continuously if possible.
- External attack surface scans (internet-facing assets) must be performed monthly.
- Newly deployed systems must be scanned before production release.

6.0 Risk Rating and Prioritization

All vulnerabilities must be classified using a recognized framework such as:

- **CVSS v3.1** scoring
- Internal risk modifiers (asset criticality, exploit availability, business impact)

Remediation Timelines (Based on severity):

- **Critical (CVSS 9.0–10):** Fix within **72 hours**
- **High (CVSS 7.0–8.9):** Fix within **7 days**
- **Medium (CVSS 4.0–6.9):** Fix within **30 days**
- **Low (CVSS 0–3.9):** Fix within **90 days**

Exceptions require formal documented approval.

7.0 Patch and Remediation Process

- Apply patches during approved maintenance windows.
- Implement compensating controls if patching is delayed.
- Validate and rescan systems after remediation to confirm closure.
- Track remediation through a ticketing or GRC system.

8.0 Reporting and Metrics

The Security Team must produce:

- Monthly vulnerability status reports
- Metrics such as:
 - Number of open vulnerabilities by severity
 - Mean Time to Remediate (MTTR)
 - Percent of systems compliant with patch timelines
 - Trends and recurring vulnerabilities

9.0 Compliance

This policy supports compliance with ISO 27001, CIS Controls, NIST CSF, PCI-DSS, and other regulatory frameworks. Violations may result in disciplinary action.